

Cybersecurity Maturity Assessment

Executive Summary

Prepared for:	Meridian Bridge Capital — Leadership Team
Prepared by:	James Bui, GRC Analyst
Assessment date:	May–June 2026
Framework:	NIST Cybersecurity Framework 2.0 (Feb 2024)
Scope:	Functions: Protect, Detect, Respond, Recover
Classification:	CONFIDENTIAL — Executive Distribution Only

Overall Maturity Scorecard

PROTECT	DETECT	RESPOND	RECOVER	OVERALL
1.8 / 4	1.5 / 4	1.7 / 4	1.6 / 4	1.7 / 4
Target: 3.4	Target: 3.1	Target: 3.2	Target: 3.0	Target: 3.2

Scores represent average current maturity tier (1 = Partial / 4 = Adaptive) across assessed subcategories. Targets reflect the minimum tier required to satisfy regulatory obligations and capital partner expectations.

Assessment Context

Meridian Bridge Capital operates as a fintech-enabled commercial lender with approximately 180 employees across three offices. The business processes borrower PII, financial records, and proprietary underwriting data on a cloud-native AWS infrastructure with a secondary GCP analytics environment. MBC is subject to GLBA, the FTC Safeguards Rule, and state-level breach notification laws across its lending markets.

This assessment evaluated 52 subcategories across the Protect, Detect, Respond, and Recover functions of the NIST Cybersecurity Framework 2.0. Each subcategory was scored on a four-tier maturity scale. Scores reflect control evidence, open known issues, and assessor observation. Ten priority findings were identified,

documented with severity ratings, remediation recommendations, and a phased 12-month remediation roadmap.

Top 5 Priority Findings

F-01 Critical

Unencrypted Data Transmission to State Regulator

An active file transfer channel to a state regulator sends borrower financial data without encryption, in direct violation of FTC Safeguards Rule requirements. This is a live compliance violation with no compensating controls currently in place.

Recommendation: Replace immediately with encrypted file transfer. Notify legal to assess regulatory disclosure obligation.

F-02 Critical

No Access Reviews or Least-Privilege Controls

User access entitlements have not been reviewed or recertified, and role definitions have not kept pace with 50% headcount growth over 18 months. Overprivileged accounts are the primary attack surface for credential-based intrusion and insider risk.

Recommendation: Implement quarterly access reviews. Define role-based access profiles and remediate overprovisioned accounts within 30 days.

F-03 Critical

Incident Response Plan Untested, External Retainer Expired

The IR plan has not been tested through a tabletop exercise, and the external incident response retainer has expired. MBC currently has no validated capability to respond to a breach and no external support on retainer if one occurs.

Recommendation: Renew the DFIR retainer. Conduct a tabletop exercise within 60 days. Update the IR plan to reflect current architecture.

F-04 Critical

Production Borrower Data Present in Non-Production Environment

Live borrower PII has been found in the staging environment, where access controls are materially less restrictive than production. This is a documented open issue with no remediation timeline.

Recommendation: Purge production data from staging immediately. Implement data masking for all non-production environments.

F-05 High

Multi-Factor Authentication Not Consistently Enforced

MFA is not enforced on all systems, including legacy platforms and several internal applications. The legacy servicing portal maintains accounts outside the central identity provider with no MFA requirement, creating direct credential theft exposure.

Recommendation: Enforce MFA on all internet-facing systems and privileged access paths within 30 days. Migrate legacy portal accounts into the IdP within 90 days.

Remediation Roadmap at a Glance

Phase 1 Immediate	Months 1–3	Close active regulatory exposure. Stabilize identity management and incident response capability.	F-01, F-02, F-03, F-04, F-05	~\$143K
Phase 2 Near-term	Months 3–6	Deploy detective control layer (SIEM, EDR). Validate recovery capability. Build RCA process.	F-06, F-07, F-08, F-09	~\$195K
Phase 3 Planned	Months 6–12	Crisis communications planning. Backup restoration testing. Threat intelligence integration.	F-10 + 2 items	~\$35K
TOTAL	12 months	10 findings across 4 CSF functions	10 findings	~\$373K

Cost estimates reflect blended internal labor (\$200/hr) and third-party consulting (\$300/hr). SIEM and EDR estimates assume a mid-market vendor and do not include multi-year licensing discounts.

Business Context and Risk Rationale

- **Regulatory exposure is immediate.** Two findings represent active violations of FTC Safeguards Rule and GLBA data protection requirements — not hypothetical risks. An examination or notifiable breach event before these are remediated creates direct enforcement exposure.

- **Incident response capability is currently inadequate.** The combination of an untested IR plan, expired DFIR retainer, and no real-time detection means MBC's ability to contain and respond to a breach is unvalidated. Given the borrower PII in scope, this is the single highest-consequence gap.

- **The \$373K remediation investment is proportionate to the risk.** The average cost of a financial services data breach exceeds \$5.9M (IBM Cost of a Data Breach Report, 2024). The GLBA civil penalty for a single enforcement action can reach \$100K per day. The remediation spend is a fraction of either outcome.

- **SOC 2 Type II readiness requires closing Phase 1 and most of Phase 2.** Capital partners and institutional investors increasingly require SOC 2 reports as a condition of continued investment. Phase 1 findings (access reviews, MFA, data protection) are near-certain audit failures in their current state.

Recommended Immediate Actions

--	--	--	--

1	Replace unencrypted FTP channel to state regulator with SFTP/HTTPS.	IT / Security	Week 2
2	Engage legal to assess regulatory disclosure obligation for F-01.	Legal	Week 2
3	Purge production borrower data from staging environment.	Engineering	Week 3
4	Sign new DFIR retainer and schedule tabletop exercise.	Security / Legal	Month 1
5	Begin quarterly access review cycle; freeze new entitlements pending review.	IT / HR	Month 1

The findings and recommendations in this report are based on evidence gathered during a structured assessment conducted in May–June 2026. Full methodology, subcategory scores, and detailed finding documentation are available in the accompanying technical workbook. This summary is intended for executive review and does not constitute legal or regulatory advice.

Assessment performed by James Bui · Framework: NIST CSF 2.0 · June 2026